

٣٠ — فلو كل سيناريو في التطبيق • تسليم لفريق الاختبار

<!-- doc-owner -->

المالك: Business analysis — هو وحده من يكتب في هذه الوثيقة.

لاحظت خطأ؟ راسله ولا تصلحه بنفسك — راجع OWNERS.md.

<!-- doc-owner -->

إلى: مطور الاختبار (Tester / QA Dev)

التاريخ: 2026-09-10

مبنية على: الكود نفسه — ١٠٦ مسار API صريح، و٢٨ موردًا لكل منها ست عمليات،

و١٨٧ رمز خطأ مرفوعًا من القاعدة. لا شيء هنا مأخوذ من وثيقة أو ذاكرة.

كيف تُقرأ هذه الوثيقة

كل سيناريو مكتوب بأربعة أجزاء:

الجزء	ما فيه
الفلو	الخطوات بالترتيب: الشاشة ← المسار ← دالة القاعدة ← تغيير الحالة
الحالة المتوقعة	ما يجب أن تراه في القاعدة بعد النجاح — نقطة التأكيد
المسارات السالبة	ما يجب أن يُرفض، وبأي رمز
ملاحظة	ملاحظتي أنا — تُقرأ ولا تُختبر، إلا إن قلت غير ذلك

قاعدة تحكم كل حالة اختبار هنا: أكد رمز الخطأ نفسه، لا مجرد وقوع رفض.

حالة تنتظر رفضًا فيأتيها رفض لسبب آخر لم تثبت شيئًا وتبدو خضراء. هذه ليست

نصيحة عامة — إنها درس مدفوع الثمن في هذا المشروع بعينه، مسجل في CLAUDE.md.

وقاعدة ثانية: كل حالة تختبر رفضًا تُشغّل بدور hbh_app صراحةً.

hbh_owner يتجاوز RLS والمنح معًا، فاختبار رفض بدوره يثبت أن المالك يمرّ —

وهو ما نعرفه سلفًا. وقعنا في هذا فعلًا.

أ — الهوية والدخول

١.أ — دخول وليّ الأمر برمز التحقق (OTP)

الفلو

#	الخطوة	المسار	ما يحدث في القاعدة
١	يدخل رقم الجوّال	POST /api/v1/auth/otp/request	request_otp — يُنشأ صفّ في otp_codes مُجرّأً
٢	يصله الرمز	—	⚠ لا مُرسِل SMS. خارج الإنتاج يعود الرمز في الردّ (dev_code)
٣	يدخل الرمز	POST /api/v1/auth/otp/verify	verify_otp ← create_auth_session — توكن مُجرّأً في auth_sessions
٤	يصل للبوّابة	GET /api/v1/me	الهوية تُضبط بـ SET LOCAL لكل طلب

الحالة المتوقّعة: صفّ في auth_sessions بتوكن مُجرّأً لا خام otp_codes.used_at · مملوء · صلاحية الجلسة ٤٨٠ دقيقة (SESSION_TTL_MINUTES).

المسارات السالبة

المتوقّع	الحالة
رفض · والعّدّاد يزداد ويبقى بعد الرفض	رمز خاطئ
الحساب يُقفّل (OTP_MAX_ATTEMPTS = 5)	٥ محاولات خاطئة
رفض — لمرة واحدة فقط	رمز مستعمل مرّة
رفض (OTP_TTL_MINUTES = 15)	رمز منتهٍ
رفض (OTP_RESEND_SECONDS)	طلب رمز جديد قبل ٦٠ ثانية
HB011	حساب مقفول يحاول فتح جلسة
رفض بقاعدة MOBILE_PATTERN	جوّال بصيغة غير 01XXXXXXXX

📌 أهمّ حالة اختبار في هذا القسم كلّها: «رمز خاطئ ← العدّاد يزداد».

الدالة كانت ستُزيد العدّاد ثم ترفع استثناء — والاستثناء **يفكّ المعاملة ويأخذ الزيادة معه **. النتيجة: تجربة رموز بلا حدّ. أصلحت بأن تُرجع الدالة حالة بدل أن ترفع. اختبرها بعدّ الصفوف بعد الرفض، لا بالتقاط الاستثناء.

📌 OTP_ECHO يجب أن يكون مطفأً في الإنتاج. لو رجع dev_code من بيئة إنتاج

فهذه ثغرة كاملة: رمز دخول أي وليّ أمر لمن يعرف رقم موبايله. **اجعلها حالة اختبار في بيئة الإنتاج نفسها** — لا في التطوير.

أ.٢ — دخول الموظف بكلمة مرور

الفلو: `POST /api/v1/auth/staff/login` ← `create_auth_session`

المسارات السالبة

الحالة	المتوقع
كلمة مرور خاطئة	<code>BAD_CREDENTIALS</code> · العدّاد يزيد
تجاوز <code>LOGIN_MAX_ATTEMPTS</code>	قفّل لمدة <code>LOGIN_LOCK_MINUTES</code>
مستخدم ليس من نوع كلمة مرور	<code>NOT_PASSWORD_USER</code>
مستخدم مؤرشف	رفض

أ.٣ — تفعيل حساب جديد · تغيير كلمة المرور

الفلو	المسار
الإدارة تُصدر رابط تفعيل	<code>POST /api/v1/users/{id}/password-setup</code> ← <code>issue_password_setup</code>
الموظف يستبدله	<code>POST /api/v1/auth/password-setup</code>
يغيّر كلمته بنفسه	<code>POST /api/v1/auth/password</code> ← <code>change_own_password</code>

سالب: كلمة أقصر من `MIN_PASSWORD_LENGTH` · رابط مستعمل · رابط منته.

أ.٤ — الحاجز الأمني ⚠️ أهم مجموعة في المشروع

السؤال الوحيد: هل يصل وليّ أمر إلى طفل ليس طفله — بأي طريق؟

الحالة	المتوقع
وليّ أمر (أ) يقرأ <code>GET /children</code>	طفله وحده
وليّ أمر (أ) يقرأ <code>GET /children/{معرّف طفل ب}</code>	صفر صفوف / رفض — لا بيانات
نفس الشيء على <code>/plans</code> <code>/notes</code> <code>/invoices</code> <code>/reports</code> <code>/sessions</code> <code>/activities</code>	كلّها
طلب بلا هوية	صفر صفوف — لا كل الصفوف

👉 «لا هوية = صفر صفوف» هو العقد. والانحراف الشائع أن سياسة تسمح بصفوف `center_id IS NULL` فتسريها لاتصال غير مصادق. **اختبر مسارًا واحدًا على الأقل بلا توكن وأكّد أنه لا يعيد صقًا واحدًا** — لا أنه يعيد ٤٠١ فحسب.

📌 الاختبار عبر HTTP لا عبر SQL. فحص السياسة مباشرة في القاعدة يثبت أن السياسة سليمة؛ وفحصها من وراء الشبكة هو الوحيد الذي يثبت أن طبقة Go لا تفتح بابًا جانبيًا.

ب — طلب الالتحاق (الدخول الأول للطفل)

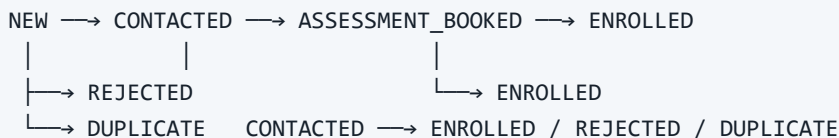
ب.١ — الأهل يقدمون طلبًا · بلا مصادقة

الفلو: الموقع التعريفي ← زر يشير إلى `/apply` في البوابة ← `POST /api/v1/enrolments` — المسار الوحيد الذي يكتب بلا توكن. سالب: إغراق بالطلبات ← يجب أن يحده `rateLimited`. اختبره.

📌 هذا المسار هو السطح الأكثر عرضة في النظام ككله — كتابة بلا مصادقة على إنترنت مفتوح. أعطه من حالات الاختبار السالبة أكثر مما تعطي أي مسار آخر: حقول ضخمة، محارف تحكّم، HTML، تكرار، حقول ناقصة.

ب.٢ — الاستقبال يفرز الطلب

آلة الحالة — `legal_enrolment_transition`:



المسار: `PATCH /api/v1/enrolments/{id}`

سالب — والأهم: أي انتقال غير مذكور أعلاه يُرفض. جرّب `NEW → ENROLLED` مباشرة، و `REJECTED → CONTACTED`، و `ENROLLED → NEW`.

ب.٣ — تحويل الطلب إلى ملفّ طفل

المسار: `POST /api/v1/enrolments/{id}/convert` ← `convert_enrolment`

الحالة المتوقعة: صفّ في `children` · `converted_child_id` مملوء · الحالة `ENROLLED`. سالب: التحويل من حالة غير `ENROLLED` · التحويل مرّتين لنفس الطلب.

`convert_enrolment` ينقل أربعة أعمدة فقط (الاسم، الميلاد، النوع، الرقم القومي). **الشكوى الرئيسية والتاريخ العلاجي يبقيان في صفّ الطلب ولا يصلان ملفّ الطفل. ليس فقدانًا — الطلب مربوط — لكنّه يعني أن قراءة ملفّ طفل لا تُظهر سبب مجيئه**. مسجّل كـ BL-16 .

`WHERE national_id IS NOT NULL` طفلان بلا رقم قومي يجب أن يُقبلا. الفهرس جزئي .
اختبرها بصقّين على نفس جانب القاعدة — أي طفلين كلاهما بلا رقم. هذا بالضبط العيب الذي وصل الإنتاج في أوراكل ونجا من ٧٣ اختبارًا لأن الاختبار كان بصفّ برقم وصفّ بدونه، وهما لا يتصادمان أبدًا.

ج — الجدولة

ج.١ — الاستقبال يحجز موعدًا

الفلو

#	الخطوة	المسار	القاعدة
١	فحص الخانة قبل الحجز	<code>POST /api/v1/appointments/validate</code>	<code>validate_slot</code>
٢	الحجز	<code>POST /api/v1/appointments</code>	<code>BOOKED</code> → <code>book_appointment</code>

الحالة المتوقّعة: صفّ `appointments` بحالة `BOOKED` + صفّ في `appointment_status_history` .

المسارات السالبة — قلب هذا القسم

الحالة	المتوقّع
موعدان متداخلان في نفس الغرفة	رفض بـ <code>EXCLUDE</code>
موعدان متداخلان لنفس الأخصائي	رفض بـ <code>EXCLUDE</code>
موعد داخل إجازة أخصائي	رفض — <code>validate_slot</code> تفحص <code>schedule_blocks</code>
موعد يوم إغلاق المركز	رفض
موعد خارج ساعات عمل الأخصائي	رفض
نافذة مقلوبة (النهاية قبل البداية)	<code>BAD_WINDOW</code> — لا <code>22000</code>
خدمة غير مربوطة بالأخصائي	رفض

🔗 اختبار التداخل ببدء مباشر على القاعدة أيضًا، لا عبر ال API وحدة. القيد

EXCLUDE في المحرّك، فهو يرفض حتى لو تجاوز أحدهم الطبقة. وهذا يستحقّ حالة تُثبتته — لأنه أقوى ما في هذا النظام، وأسهل ما يُضعف بلا انتباه.

🔗 حالة السباق: طلبا حجز متزامنان على نفس الخانة. المتوقّع أن **واحدًا يمرّ

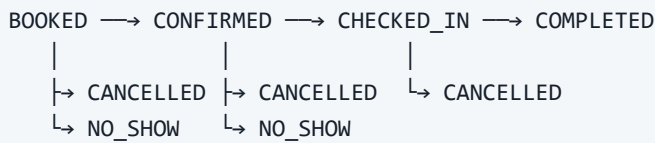
وواحدًا يُرفض ** — لا الاثنان. هذه لا تُكتشف بالاختبار التسلسلي إطلاقًا.

🔗 قيد الغرفة صحيح لغرفة وخاطئ لصالة ٥٠٠٠ متر. الأماكن الخارجية (بيلي بيز

وغيرها) ستُرفض بلا سبب مفهوم للمستخدم. لا تكتب حالة اختبار لهذا بعد — القرار معلّق عند المالك (BL-15).

ج.٢ — تحرّك حالة الموعد

آلة الحالة — legal_appointment_transition :



المسار: PATCH /api/v1/appointments/{id}/status

سالب: BOOKED → CHECKED_IN (قفزة) · أي شيء → COMPLETED · CANCELLED → BOOKED

← كلّها HB024 بصيغة «% appointment % cannot go from % to %».

⚠️ 📄 فجّ يخصّ كاتب الاختبار لا المنتج: كل انتقال حالة جملة SQL مستقلة.

جملة واحدة تنقل الموعد BOOKED → CONFIRMED → CHECKED_IN **تتركه عند CONFIRMED

بصمت ** — الصفّ لا يُحدّث إلا مرّة واحدة في الجملة الواحدة، بلا خطأ ولا تحذير.

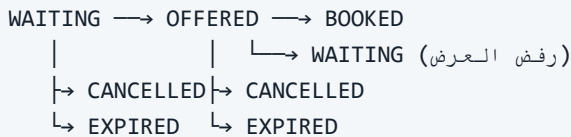
فيُرفض ما بعده بـ HB024 بدل HB023 — رفض للسبب الخطأ لا يثبت شيئًا.

إن بنيت تجهيزتك بجملة واحدة، ستكتب اختبارًا أخضر يثبت العكس.

ج.٣ — الحجز المتكرر · قائمة الانتظار

الفلو	الدالة
حجز دورة متكررة	book_recurring — من ١ إلى ٥٢ جلسة
إلغاء الدورة	cancel_recurrence
إضافة لقائمة الانتظار	add_to_waiting_list
عرض خانة	offer_slot
قبول العرض	accept_offer

آلة حالة الانتظار:



سالب: دورة بـ ٠ أو ٥٣ جلسة ← «a course is between 1 and 52 sessions»

BOOKED → OFFERED · قبول عرض منتهٍ.

د — الجلسة العلاجية (القلب السريري)

د.١ — بدء الجلسة

المسار: POST /api/v1/appointments/{id}/session

الشرط: الموعد CHECKED_IN حصرًا.

سالب

الحالة	الرمز/الرسالة
الموعد BOOKED أو CONFIRMED	«appointment % is % — a session starts only from CHECKED_IN»
الموعد له جلسة سلفًا	«appointment % already has a session»
موعد غير موجود	«% no such appointment»

د.٢ — ملاحظة الجلسة

المسار: PUT /api/v1/sessions/{id}/note ← مسودة (is_draft_flg = true)

ثم POST /api/v1/notes/{id}/publish ← publish_session_note

⚠ حالة اختبار لا يُكتشف عيبها بغيرها، وقد وقع فعلاً:

أخصائية (أ) لا يجوز أن تُغلق جلسة أخصائية (ب). الدالة كانت تسمح بذلك، لأن

التجاوز الإداري بُني على الصلاحيات وحدها — ودور THERAPIST يملك

CHILD.VIEW_ALL و SESSION.COMPLETE معًا. الخطّ الصحيح:

الإكلينيكي يُغلق عمله هو، والإداري (user_type = 'STAFF') يُغلق عمل أي أحد.

وتجهيزتك يجب أن تستطيع إنتاج الرفضين لتفرّق بينهما: مجموعة فيها أخصائية

واحدة — وهي صاحبة الجلسة — تمرّر أي رمز خطأ، لأن حالة «يملك الصلاحية ولا يملك

الجلسة» غير قابلة للتكوين فيها أصلاً. تحتاج **زميلة تملك SESSION.NOTES.EDIT

ولا تملك جلسة، وتؤكد صلاحيتها بالاسم ** قبل الاختبارات.

👉 ومدير المركز لا يملك SESSION.NOTES.EDIT — بالقصد. أگّدها: هي تفرقة

«إداري» عن «إكلينيكي» في أوضح صورها.

د.٣ — إغلاق الجلسة

المسار: close_session ← PATCH /api/v1/sessions/{id}/close

آلة الحالة: IN_PROGRESS → COMPLETED أو IN_PROGRESS → ABORTED . لا ثالث.

ما يقع عند الإغلاق: إغلاق توكنات البث (close_session_streams) .

خصم من الباقة (consume_package_session) . إشعار الأهل (notify_guardians) .

👉 ** consume_package_session كانت تعلّم الباقة EXPIRED ثم ترفع استثناء —

فلا تعلّم أبداً**، لأن الاستثناء يفكّ المعاملة. العلاج: التعليم نداء مستقلّ

(expire_packages). اختبر: باقة منتهية عند الإغلاق — هل علّمت فعلاً؟

بعد الصفوف بعد العملية، لا بالتقاط استثناء.

د.٤ — الخطط والأهداف والقياسات

الحالات	الكيان
DRAFT → ACTIVE → COMPLETED/CANCELLED	treatment_plans
OPEN → DROPPED أو OPEN → MET	plan_goals
قياس بنسبة value_pct مربوط بجلسة	goal_measurements

سالب: COMPLETED → ACTIVE . قياس على هدف DROPPED . نسبة خارج ٠-١٠٠.

د.٥ — تقرير التقدّم

الفلو: إنشاء (DRAFT) ← POST /api/v1/reports/{id}/publish ← publish_report

قاعدة صلبة: لا يُنشر تقرير بلا لقطة أهداف (goals_snapshot) — فالتقرير

المنشور لا يتغيّر تحت أقدام الأسرة.

سالب: نشر بلا لقطة · تعديل تقرير منشور.

👉 **سَلَمُ الرؤية** هو أدقّ ما في هذه المنطقة: INTERNAL لا يراه وليّ الأمر أبدًا،

و PARENT يراه. **اختبر كل كيان له visibility من عينيّ وليّ الأمر:** ملاحظة،

مرفق، تقرير. أحدها ينسى المطوّز ربطه يومًا.

د.٦ — التقييمات

record_assessment ← publish_assessment · الحالات . DRAFT → COMPLETED → PUBLISHED

هـ — البرنامج المنزلي

الفلو	المسار
الأخصائي يُسند نشاطًا	child-activities على CRUD
وليّ الأمر يرى الأنشطة	GET /children/{id}/activities
وليّ الأمر يسجّل تنفيذ نشاط	log_activity ← POST /children/{id}/activities/{id}/log
سجّل التنفيذ	GET /children/{id}/activity-log

👉 **هذا واحد من مسارين فقط يكتب فيهما وليّ الأمر** (الآخر: الطلبات). أعطه وزنًا

في الاختبار السالب: تسجيل نشاط لطفل آخر، تسجيل نشاط غير مُسند، تسجيل مكرّر.

و — الطلبات (وليّ الأمر ← الاستقبال)

الفلو: POST /children/{id}/requests ← log_request →

decide_request ← PATCH /api/v1/requests/{id}

الأنواع: CALLBACK · CANCEL · RESCHEDULE — ثلاثة، ولا رابع.

الحالات: NEW → ACCEPTED أو NEW → REJECTED .

سالب: البتّ في طلب مبتوت · طلب على طفل غير مرئي ← «child % is not visible».

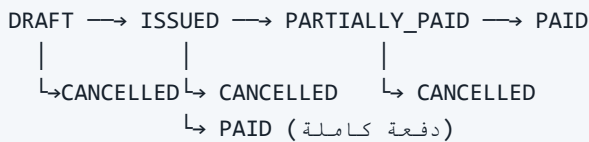
⚠️ حالة اختبار تخصّ بيئة مشتركة، ووقعت فعلاً: لا تقرأ request_id من

قائمة الطلبات ثم تبتّ فيه. القائمة مفهرسة بالمركز وتحوي صفوف الآخرين**بحكم تصميمها الصحيح** — فتقع على صفّ بيانات عرض لطرف ثالث وتختمه باسم حسابك. كل معزّف يدخل حالة اختبار يُقرأ بمفتاح التجهيزة نفسها، لا من ترتيب قائمة.

📌 لا يوجد نوع «طلب حجز جديد». وليّ الأمر لا يحجز — الحجز من الاستقبال وحده. لا تكتب حالة اختبار لزر «احجز جلسة» في البوابة: غير موجود بالقصد (BL-03).

ز — الفوترة

ز.١ — دورة الفاتورة الكاملة



#	الخطوة	المسار	الدالة
١	إنشاء	POST /api/v1/invoices	create_invoice
٢	إضافة بند	POST /invoices/{id}/lines	recalc_invoice → add_invoice_line
٣	حذف بند	DELETE /invoices/{id}/lines/{lid}	
٤	إصدار	POST /invoices/{id}/issue	issue_invoice
٥	دفعه	POST /invoices/{id}/payments	

سالب — غنيّ، اختبره كلّ

الحالة	الرسالة
دفعه على فاتورة مسوّدة	«invoice % is still a draft and cannot take a payment»
دفعه على فاتورة ملغاة	«invoice % is cancelled and cannot take a payment»
تعديل بنود فاتورة مُصدّرة	«invoice % is % — its lines cannot be changed»
بلا صلاحية BILLING.MANAGE	«creating/changing/issuing an invoice needs BILLING.MANAGE»
انتقال غير شرعي	«% invoice % cannot go from % to»

⚠️ أخطر فجّ في اختبار الفوترة، ووقع فعلاً:

مشغّل **BEFORE** يعمل قبل فحص **WITH CHECK** في **RLS**. أي أن ****قاعدة العمل** تجيب أولاً وتحجب رفض الصلاحية تماماً: دفعة على فاتورة مسوّدة تُرفض بـ **HB052** لأي أحد — والاستقبال بلا صلاحية لا يصل إلى السياسة أصلاً**.

فاختبار الصلاحية يحتاج صفّاً تقبله قاعدة العمل أولاً. لتختبر «بلا

BILLING.MANAGE يُرفض»، ابدأ من فاتورة مُصدّرة تقبل الدفع فعلاً. وإلا كتبت اختباراً أخضر يثبت قاعدة عمل ويظنّ أنه أثبت صلاحية.

📌 **سعر الجلسة المفردة يُكتب يدويّاً في كل فاتورة** — لا جدول أسعار. فلا يوجد

«السعر الصحيح» للتحقّق منه. اختبر الحساب (`line_amt = round(qty × unit_amt, 2)`) لا القيمة (`BL-19`).

ز.٢ — الباقات

بيع: `POST /children/{id}/packages` · خصم: `consume_package_session` عند

إغلاق الجلسة · حالات: `ACTIVE → EXHAUSTED / EXPIRED / CANCELLED`.

سالب: خصم من باقة منتهية · من باقة مستنفدة · «% no such package balance».

ح — البثّ المباشر

الفلو: `POST /api/v1/sessions/{id}/stream` ← `can_view_live` → `issue_stream_token`

→ تشغيل `POST /api/v1/stream/close`

قواعد التوكن — كلّها حالات اختبار:

القاعدة	التأكيد
صلاحية ≥ 10 دقيقة	<code>STREAM_TOKEN_TTL_MIN</code> — ولا تزيد أبداً
مُجرّاً عند التخزين	لا توكن خام في <code>stream_tokens</code>
مربوط بـ جلسة وكاميرا ومستخدم	لا يعمل توكن على جلسة أخرى
يُلغى عند إغلاق الجلسة	<code>close_session_streams</code>
لا تسجيل — أبداً	لا جدول تسجيلات، ولا إشارة إلى مقطع

سالب: بلا موافقة `LIVE_VIEW` ← رفض · توكن منتهٍ · توكن جلسة أخرى ·

`can_view_live_flg` افتراضه رفض.

✍️ ****أكد أن الردّ لا يحمل مسار البوابة الإعلامية ولا معرّف كاميرا ولا عنوانًا ولا بيانات اعتماد. العميل يكلم ال API، وال API يكلم البوابة. اقرأ جسم الردّ حرفيًا في الحالة**** — لا تكتف ب 200 .

✍️ **كل مشاهدة تُسجّل في stream_views صراحةً.** المشغلات لا تلتقط القراءات. أكد وجود الصفّ — هذا ما يجعل «مَن شاهد ابن مَن ومتى» سؤالًا له جواب.

ط — الموافقات والصور

الفلو	المسار
منح موافقة	<code>grant_consent</code> ← <code>POST /guardians/{id}/consent</code>
سحب موافقة	<code>withdraw_consent</code> ← <code>DELETE /guardians/{id}/consent</code>
رفع صورة طفل	<code>PHOTO_USE</code> ← <code>POST /children/{id}/photo</code> — مشروط بـ

الأنواع الثلاثة: `LIVE_VIEW` · `SMS_NOTIFY` · `PHOTO_USE` . لا رابع.

✍️ ⚠️ **الدرس الأعلى في هذا القسم:**

فحص رفض بلا فحص قبول بعده لا يثبت أن البوابة تفتح — يثبت أنها مغلقة.
بوابة الصورة كانت تسأل عن 'PHOTO' ولا وجود لهذا النوع (الصحيح `PHOTO_USE`).
فكانت **بوابة بلا مفتاح**: كل صورة تُرفض. والاختبار الأول — «بلا موافقة يُرفض» —
مرّ أخضر وبدا أن كل شيء يعمل.

كل بوابة تحتاج حاليتين: تُرفض بلا الشرط، وتُمرّ به. والثانية هي التي تكتشف.

✍️ **ولا تبين حالة «لا توجد موافقة» ببناء `withdraw_consent`.** الدالة تكتب حدث سحب في `consent_events` ، وهو **سجلّ مضاف-فقط**: صفّ لا يُحذف، مع كل تشغيلة، على طفل بعينه — فيقول السجلّ إن أهله سحبوا موافقتهم عشرين مرّة. ****التجهيزة تبني الحالة بـ UPDATE مباشر، والدالة تختبرها**.**

✍️ **والحالة المبدئية تُصنّع لا تُفترض.** «لا موافقة بعد» افتراض يكسره: مجموعة أخرى تسجّل نفس النوع، أو معرّف طفل أعيد استعماله بعد حذف صلب. ****اسحب الحالة صراحةً قبل أن تختبر غيابها****، وإلا اختبر اختبارك لا شيء.

ي — استبيان الرضا (NPS)

GET /api/v1/nps/due ← nps_due → POST /nps/{id}/response أو /skip
GET /api/v1/nps/summary (للمركز) →

سالب: ردّ مرتين على نفس الاستبيان · ردّ على استبيان غير مستحقّ · درجة خارج ٠-١٠٠.

ك — رسائل الأسرة

GET | POST /family-messages/{guardian_id} · GET /family-contacts
POST /family-messages/{id}/read

سالب: وليّ أمر يقرأ محادثة وليّ أمر آخر — حالة حاجز، أعطها وزنًا.

ل — الإدارة

ل.١ — المستخدمون والأدوار

الفلو	المسار
إنشاء مستخدم	POST /api/v1/users ← create_user
تعديل / أرشفة	DELETE · PATCH ← archive_user
إسناد أدوار	PUT /users/{id}/roles
صلاحيات الدور	PUT /roles/{code}/permissions

سالب — والأهم: أرشفة آخر مدير ← guard_last_admin يمنعها. اختبرها.

ل.٢ — الإعدادات

PATCH /settings/center · GET | PATCH | DELETE /settings/params/{code}
← guard_center_settings

البارامترات هي مصر: العملة، المنطقة الزمنية، العطلة، صيغة الجوّال، طول الرقم القومي. لا شيء منها في الكود. حالة اختبار تستحقّ الكتابة: **غَيّر MOBILE_PATTERN وأكد أن التحقق تغيّر فعلاً** — تثبت أن التوطين بيانات لا كود.

RECORDING_ENABLED = false ولا تُغيّر. القيمة للتوثيق. لو صار تغييرها يفعل شيئًا، فقد سقطت قاعدة دائمة بلا قرار.

ل.٣ — ملفّ الأخصائي والموقع

publish_therapist_profile ← DRAFT → PUBLISHED → WITHDRAWN

موافقة الأخصائي POST|DELETE /therapists/{id}/consent

سالب: نشر ملفّ بلا موافقة الأخصائي.

م — ما يعمل في الخلفية

المهمّة	كيف تُشغّل	ماذا تختبر
الصيانة الدورية	run_maintenance · db.sh maintenance	صفّ في maintenance_runs بمعزّفه
صحة المهامّ	GET /ops/health · db.sh health	MAINTENANCE_MAX_AGE_MIN
انتهاء الباقات	expire_packages	ACTIVE → EXPIRED عند الاستحقاق
أرشفة التدقيق	archive_audit	الصفوف تنتقل إلى audit_log_archive ، وثقراً عبر v_audit_trail
النسخ الاحتياطي	record_backup · backup.sh backup_health	

⚠ حالة اختبار على archive_audit لا يفكّر فيها أحد: الدالة **تعطّل مشغّل حماية لتنقل الصفوف. أكّد أنها أعادته قبل أن تعود** — وإلّا تركت سجلّ التدقيق قابلاً للكتابة وسكتت. الأثر لا يظهر إلّا يوم يُحتاج السجلّ.

📁 الأرشفة نقل، والحذف حذف. أي «سياسة احتفاظ» تحذف من audit_log مرفوضة. اختبر: بعد الأرشفة، هل الصفّ ما زال مقروءاً عبر v_audit_trail ؟

⚠ backup.sh يجب أن يقف — لا يحذّر — عند أي مجلّد مزامنة. النسخ كانت تنزل في backups/ داخل المشروع، والمشروع تحت «سطح المكتب» المُعاد توجيهه إلى OneDrive: **كل dump فيه السجلّ السريري الكامل لكل طفل كان يُرَقّع إلى حساب سحابي شخصي تلقائياً. بلا خطأ ولا سؤال ولا سطر في أي لوج. ** حالة اختبار: وجّه النسخة إلى مجلّد مزامنة وأكّد أن السكربت يقف بكود خروج غير صفري. ** التحذير يمزّ — وال فشل يُكتشف حين تسأل عن بيانات وصلت مكاناً لم يقصده أحد.

ن — قواعد تسري على كل حالة اختبار

#	القاعدة	لماذا
١	أكد رمز الخطأ نفسه	رفض لسبب آخر لم يثبت شيئاً ويبدو أخضر
٢	كل فحص رفض يسبقه SET ROLE hbh_app	hbh_owner يتجاوز RLS والمنح معاً
٣	أكد التجهيزة بالاسم قبل الاختبارات	قطعة منسيّة تظهر بعد ٥٠ فحصاً كرفض محيّر من كود سليم
٤	كل عدّ مقيّد بمفتاح تجهيزتك	القاعدة مشتركة بين جلسات؛ count(*) على جدول كامل يكسره الجار
٥	الشكل الصامد: «واحد على الأقل، ثم لم يبقَ شيء»	المعرّفات تُعاد بعد الحذف الصلب، فعدد بعينه ينكسر
٦	التنظيف يحذف بالهوية لا بالتشابه	mobile LIKE '015000000%' طابق صفّ تجهيزة أخرى وأسقط ٢١ فحصاً
٧	التنظيف فحص مسجّل	تنظيف يبتلع فشله أسوأ من غياب التنظيف
٨	الحكم يُطبع دائماً ثم يُرفع الاستثناء	مجموعة تموت قبل حكمها تُقرأ كنجاح
٩	db.sh reset ممنوع على قاعدة مشتركة	يسحب السكيما من تحت جلسة أخرى؛ migrate فقط

ما لا تكتب له حالات اختبار — بعدّ

البند	لماذا
زر «احجز جلسة» في البوابة	غير موجود بالقصد — BL-03 معلق
بوابة الدفع الإلكتروني	غير مبنية — BL-04
رفع فيديو	ممنوع بـ BL-05
إشعار يصل فعلاً للأهل	لا مُرسِل — الصفت يُكتب ولا يُرسل — BL-08
عدّاد الجلسة · تقييم الاستجابة · إشغال الغرف	غير مبنية — BL-06 · BL-09 · BL-10

تفصيلها في 02-requirements-gap-and-backlog.md

حالة اختبار تفشل على شيء لم يُبنَ ليست عيباً — إنها ضجيج يخفي العيوب الحقيقية.

الترتيب المقترح للتنفيذ

الأولوية	المجموعة	لماذا أولاً
١	أ.٤ — الحاجز الأمني	العيب الوحيد الذي يؤدي أسره حقيقية
٢	ج.٢ — انتقالات الحالة	فجّ الجملة الواحدة يفسد التجهيزات تحته كلّها
٣	د.٢ — صلاحية إغلاق الجلسة	عيب وقع فعلاً، ولا يُكتشف بتجهيزة أخصائية واحدة
٤	ز.١ — الفوترة	ترتيب المشغل قبل RLS يجعل الأخضر كاذباً
٥	ح — البثّ	التوكن يحمل أخطر ما في النظام
٦	الباقي	

الملاحظات المفتوحة على التطبيق: 04-app-notes.md